Assignment 1 - Performing a Gap Analysis for CMMC Readiness

Identify cybersecurity gaps by comparing current practices against CMMC v2.0 requirements using a structured checklist, and outline your next remediation steps.

In this assignment, you'll simulate the process of conducting a **CMMC v2.0 gap analysis** for a company aiming for Level 2 compliance. You will be provided a simplified gap analysis checklist. Based on the fictional scenario, assess whether the current practices meet, partially meet, or do not meet the controls. Then, identify three remediation tasks and prioritize them based on potential impact and feasibility.

This exercise will help you apply practical gap analysis skills, understand how to evaluate compliance posture, and create a risk-based remediation plan—all essential for preparing for CMMC audits.

Scenario:

Your company handles Controlled Unclassified Information (CUI) as part of subcontracting for aerospace defense components. You are tasked with conducting a preliminary gap analysis to check readiness for **CMMC Level 2**. Below is a partial checklist from NIST SP 800-171 aligned controls.

Gap Analysis Checklist (Excerpt):

Gap Analysis Checklist (Excerpt):

Control Area	Example Control	Current Status
Access Control	Limit system access to authorized users only	Partially Implemented
Audit & Accountability	Enable system log review capabilities	Not Implemented
Incident Response	Define roles for incident handling	Fully Implemented
System & Info Integrity	Scan for malware regularly	Not Implemented
Risk Assessment	Conduct regular risk assessments	Partially Implemented

Questions for this assignment

Questions:

1. Based on the table, which control areas are most concerning and why?

2. Identify **three gaps** that require remediation.

3. For each gap, suggest a **remediation action** and indicate if it should be **high, medium, or low priority**.

4. What risks would remain if those gaps are not addressed?

5. How could a structured gap analysis like this support audit preparation?

Solution by the Instructor:

Questions:

1. Based on the table, which control areas are most concerning and why?

2. Identify **three gaps** that require remediation.

3. For each gap, suggest a **remediation action** and indicate if it should be **high, medium, or low priority**.

4. What risks would remain if those gaps are not addressed?

5. How could a structured gap analysis like this support audit preparation?

Solution (Sample):

1. Most concerning areas include **Audit & Accountability** and **System Integrity** because both directly affect threat detection and prevention.
2. Gaps:
    - Audit logs not implemented
    - Malware scanning missing
    - Risk assessment is incomplete
3. Remediation actions:
    - Deploy centralized log management (High Priority)
    - Install endpoint antivirus with scheduled scans (Medium Priority)
    - Schedule quarterly risk assessments (Medium Priority)
4. Risks:
    - Threats may go undetected without logs

    - Malware could disrupt operations or expose CUI
    - Poor risk awareness may lead to unaddressed vulnerabilities
5. Structured gap analysis enables focused action, documents compliance posture, and strengthens confidence during pre-audit phases.